



RTM View Shell

Security Configuration Guide

Authentication, password policy, 2FA, tokens, headers, audit

Administrator guide A-04 — for Administrator and Superadmin

Edition EN · 2026-07-03 · RTM View Shell

Document revision history

This table lists the revision history of this document.

Version	Date	Summary of changes	Product release ID	Shipped-with (commit/barrier)
1.0	2026-07-03	Initial (regenerated)	RTM-REL-2026.06	(pending push)

Contents

Document revision history.....	2
Contents.....	3
1. Security model at a glance.....	4
2. Web sign-in (cookie session).....	4
3. Password policy.....	4
4. Two-factor authentication (e-mail OTP).....	4
5. Brute-force protection.....	4
6. REST API tokens (JWT).....	4
7. Transport security and headers.....	5
8. The audit trail.....	5
9. Verification checklist.....	5
Appendix A — Security settings & where they live.....	6

1. Security model at a glance

RTM View Shell separates two authentication surfaces. The web application authenticates with a secure session cookie. The optional REST API authenticates with short-lived JSON Web Tokens (JWT). Both share the same accounts, password policy and audit trail. Most settings are per tenant (Tenant Settings, A-07); platform-wide controls (transport, headers, keys) are set at deployment (A-01).

2. Web sign-in (cookie session)

Browser sessions use a hardened cookie: HttpOnly, Secure, same-site, host-only prefix. It slides forward while you are active (30 minutes) with an absolute lifetime of 8 hours. A change to a user's role or tenant forces re-authentication immediately; an administrator can also force sign-out of all of a user's sessions.

3. Password policy

- **Minimum length 12** (configurable upward per tenant).
- Must contain an upper-case letter, a lower-case letter, a digit, and a special character.
- **History of the last 10** passwords is kept; none may be reused.
- **Expiry after 90 days** (configurable); on expiry and on first login the user must set a new password before anything else.

Passwords are stored only as salted PBKDF2-HMAC-SHA512 hashes and are never written to logs.

4. Two-factor authentication (e-mail OTP)

A 6-digit one-time code is e-mailed after the password step. Require it per user, or make it mandatory for the whole tenant (Tenant Settings → "Require 2FA for all"). The code is generated with a cryptographic RNG, valid 10 minutes, 3 attempts, resend once per minute; stored only as a keyed hash; the e-mail body contains only the code (never the subject). If SSO asserts MFA (amr=mfa), the system code is skipped.

5. Brute-force protection

- **Account lockout** — 5 failed attempts lock the account for 15 minutes.
- **Rate limiting** — the sign-in endpoint accepts at most 10 requests per minute per IP.
- **Uniform errors** — every failure returns "Invalid username or password", so an attacker cannot tell what was wrong.

Every failed attempt is audited with IP, user-agent, timestamp and a failure subtype (user not found, wrong password, tenant mismatch, tenant suspended, account locked).

6. REST API tokens (JWT)

The API issues a short-lived access token (15 minutes, RSA-signed) and a longer-lived refresh token (8 hours, configurable). The refresh token is stored hashed, delivered as a host-only cookie, and rotated on every use: each refresh revokes the old token. Reuse of a revoked token revokes ALL of that user's tokens and is audited. Access tokens can also be revoked immediately on sign-out or deactivation.

Key management

RSA signing keys are held outside source control (a vault or an encrypted file with restricted permissions) and rotated yearly, with overlapping key IDs so rotation does not interrupt service. Deployment-time task — see A-01.

7. Transport security and headers

All traffic is HTTPS (TLS 1.2+); weak ciphers and old TLS are disabled and HTTP is redirected to HTTPS. Every response carries a strict set of security headers — CSP, X-Frame-Options DENY, X-Content-Type-Options nosniff, HSTS, referrer and permissions policies. Anti-forgery is applied to web forms; the API additionally checks the request origin. Configured at deployment (A-01); verify they are present here.

8. The audit trail

Every security-relevant action is recorded in an append-only audit log: sign-in success/failure (with subtype), lockouts, sign-out, token refresh/revocation, 2FA events, SSO sign-in, password reset/change, and every user, permission-group and tenant change. Each entry records who, when (UTC), client IP and user-agent. The log cannot be edited or deleted through the application; read and export only, retained per the tenant setting (365 days default).

9. Verification checklist

- Sign-in cookie HttpOnly + Secure + same-site, sliding 30 min / absolute 8 h.
- Password policy enforces length, complexity, history of 10, 90-day expiry.
- 2FA works end-to-end; “Require 2FA for all” forces it where set.
- Lockout after 5 failures; rate limit on sign-in; uniform error message.
- API access token ~15 min; refresh rotates; reuse of a revoked token revokes all.
- HTTPS only with modern TLS; all security headers present.
- Audit entries appear for sign-in, 2FA, password and permission changes; log is read-only.

Appendix A — Security settings & where they live

Control	Scope	Where set
Password length / expiry	Per tenant	Tenant Settings (A-07)
Require 2FA for all	Per tenant	Tenant Settings (A-07)
Audit retention (days)	Per tenant	Tenant Settings (A-07)
Lockout / rate limit	Platform	Deployment config (A-01)
TLS, ciphers, HTTP → HTTPS	Platform	Server / IIS config (A-01)
Security headers	Platform	Application middleware (A-01)
JWT keys & rotation	Platform	Secrets vault (A-01)
SSO provider	Per tenant	SSO Integration Guide (A-05)